

WEBINAIRE — CYBERSÉCURITÉ APPLIQUÉE À L'ENTREPRISE

Protéger les actifs de son entreprise en 90 jours

Un plan d'action priorisé quand on n'a ni budget illimité ni équipe dédiée

Isaïe Djrolo

Architecte sécurité — 16 ans en technologies de l'information

CISSP • CISM • SC-100 • ISO 27001 LI

Séance interactive : 5 sondages en direct — gardez la fenêtre de vote ouverte.

Ce que vous repartez avec dans 120 minutes

Trois livrables concrets, pas une culture générale

1 Une feuille de route datée

21 mesures réparties en trois vagues de 30 jours, avec un responsable et une échéance pour chacune.

2 Un classeur prêt à remplir

Inventaire, plan, indicateurs et tableau de bord. Utilisable dès lundi matin, sans outil payant.

3 Cinq indicateurs

De quoi démontrer le progrès à une direction en une seule page, sans jargon technique.

Ce webinaire ne traite pas du choix des outils. Il traite de l'ordre dans lequel on agit — c'est là que se joue l'essentiel de la réduction du risque les trois premiers mois.

Selon vous, qu'est-ce qu'un actif d'entreprise ?

- A Le matériel informatique : serveurs, postes de travail, téléphones
- B Tout ce qui a une valeur pour l'organisation, y compris les données et les comptes
- C Uniquement ce qui figure à l'inventaire comptable
- D Les logiciels et les licences détenues par l'entreprise

Une seule réponse. Les résultats sont affichés dans 60 secondes.

Réponse B — un actif, c'est tout ce qui a de la valeur

Le matériel est remplaçable en 48 heures. Les données et les comptes, non.

Données

Fichiers clients, contrats, dossiers du personnel, secrets industriels

Comptes

Comptes d'administration, comptes de service, accès des prestataires

Services

Site de commande, messagerie, application métier, téléphonie

Équipements

Serveurs, postes, mobiles, équipements réseau

Dépendances

Fournisseurs infonuagiques, hébergeur, infogéreur, sous-traitants

La question utile

« Si cet élément disparaissait ce matin, qu'est-ce qui s'arrête ? »

Ces cinq familles constituent les cinq types de la colonne « Type » du classeur remis en fin de séance.

PREMIÈRE PARTIE

Trois incidents, un seul point commun

Trois scénarios ordinaires, dans des organisations de moins de 100 personnes.

Incident 1 — Le rançongiciel du vendredi soir

Entreprise de distribution, 60 personnes

Vendredi 18 h

Un compte de prestataire, resté actif après la fin du contrat, est utilisé depuis l'étranger.



Vendredi 23 h

Les droits d'administration sont obtenus. Aucune alerte : la journalisation n'existe pas.



Samedi 4 h

Chiffrement des serveurs et des sauvegardes, qui étaient sur le même réseau.



Lundi 8 h

Onze jours d'arrêt. La sauvegarde exploitable datait de six mois.

Ce qui aurait suffi : retirer le compte du prestataire, et une copie de sauvegarde hors ligne.

Incident 2 — Le virement de 10 000 000 FCFA

Cabinet de services professionnels, 25 personnes

Semaine 1

La boîte de la responsable comptable est consultée depuis un compte sans double authentification.



Semaine 2

L'attaquant lit la correspondance et attend une facture réelle.



Semaine 3

Il répond dans le fil existant avec un changement de coordonnées bancaires.



Semaine 4

Le virement part. La banque ne peut plus le rappeler.

Ce qui aurait suffi : l'authentification multifacteur, et une règle de rappel téléphonique au-dessus de 3 000 000 FCFA.

Incident 3 — Le compte d'administration partagé

Organisme de services, 40 personnes

Origine

Un compte « admin » unique, partagé par trois personnes et un ancien prestataire.



Déclencheur

Le mot de passe circule dans un fil de courriels vieux de deux ans.



Effet

Création de comptes fantômes et extraction de la base des usagers.



Constat

Impossible de savoir qui a fait quoi : aucun compte n'était nominatif.

Ce qui aurait suffi : des comptes d'administration nominatifs, et une revue trimestrielle des accès.

Le point commun

Aucun de ces incidents n'a exploité une vulnérabilité sophistiquée.

3 / 3

des incidents portaient sur un actif que
personne n'avait identifié comme critique

Un compte oublié

Prestataire parti, compte resté ouvert.

Une donnée non située

Personne ne savait où vivait l'information sensible.

Une dépendance ignorée

La sauvegarde dépendait du réseau qu'elle devait sauver.

On ne protège pas ce qu'on n'a pas listé. L'inventaire n'est pas de la paperasse : c'est la première mesure de sécurité.

Où en est l'inventaire des actifs dans votre organisation ?

A Il existe, il est à jour et il indique un responsable par actif

B Il existe, mais il n'a pas été mis à jour depuis plus d'un an

C Il existe seulement dans la tête d'une ou deux personnes

D Il n'y en a pas, ou je ne sais pas s'il y en a un

DEUXIÈME PARTIE

Cartographier en une heure

L'inventaire parfait n'existe pas. L'inventaire utile tient sur une page.

Les quatre questions qui suffisent

Posées à trois personnes différentes, elles produisent 80 % de l'inventaire

1 Qu'est-ce qui arrête l'activité ?

Faire la liste des services et applications sans lesquels on ne facture plus, on ne produit plus, on ne livre plus.

2 Où sont les données sensibles ?

Renseignements personnels, dossiers clients, données de santé, informations financières — et dans quels dépôts exactement.

3 Qui a les clés ?

Comptes d'administration, comptes de service, accès des prestataires et des anciens employés.

4 Qu'est-ce qui est visible d'Internet ?

Sites, portails, accès distants, consoles d'administration, objets connectés.

Interroger séparément la direction, la personne responsable de l'informatique et un employé de terrain : les trois listes ne se recoupent jamais complètement.

La grille d'inventaire

Douze colonnes, dont deux seulement demandent une réflexion

Identification	ID · Actif · Type · Description
Responsabilité	Propriétaire métier · Hébergement
Exposition	Exposé sur Internet · Contient des données sensibles
Cotation	Impact si indisponible · Impact si divulgué
Résultat calculé	Criticité · Priorité de traitement

Deux colonnes jaunes à coter, deux colonnes calculées automatiquement. Viser 15 à 30 lignes : au-delà, l'inventaire cesse d'être tenu à jour.

Coter l'impact sans se réunir pendant trois jours

Une échelle à quatre niveaux, deux questions par actif

1 — Négligeable

Gêne interne, aucune conséquence externe.

2 — Modéré

Une équipe perturbée moins d'une journée.

3 — Important

Activité dégradée, clients affectés, direction informée.

4 — Critique

Arrêt d'activité, notification légale, atteinte à la réputation.

Deux questions, jamais plus

1. Que se passe-t-il s'il devient indisponible ?
2. Que se passe-t-il s'il est divulgué ?

Règle de calcul

Criticité = le plus fort des deux impacts, plus 1 point si l'actif est exposé sur Internet. La criticité obtenue devient la priorité de traitement : 4 = Critique, 3 = Élevée, 2 = Moyenne, 1 = Faible.

Démonstration — l'inventaire

DÉMONSTRATION

Groupe Diallo, entreprise fictive de distribution de 40 personnes, sans ressource dédiée à la sécurité

1 18 actifs en 40 minutes

Le résultat réel d'un atelier d'une matinée, avec trois interlocuteurs.

2 Trois actifs critiques

La base clients, les comptes d'administration infonuagiques, le site de commande.

3 Une surprise

L'actif le plus critique n'appartenait à personne : la sauvegarde.

Ce que vous allez voir à l'écran : la saisie de deux actifs en direct, le calcul automatique de la criticité, et l'effet du passage d'un actif en « exposé sur Internet » sur sa priorité de traitement.

TROISIÈME PARTIE

Le plan 90 jours

Trois vagues, vingt et une mesures, un responsable par ligne.

VAGUE 1 • Jours 1 à 30

Arrêter l'hémorragie

8 mesures

VAGUE 2 • Jours 31 à 60

Structurer

7 mesures

VAGUE 3 • Jours 61 à 90

Tenir dans la durée

6 mesures

Vous disposez de dix jours et d'une seule personne. Par quoi commencez-vous ?

- A** Acheter et déployer un antivirus de nouvelle génération
- B** Activer l'authentification multifacteur sur les comptes d'administration
- C** Faire réaliser un test d'intrusion
- D** Rédiger une politique de sécurité
- E** Sensibiliser l'ensemble du personnel

Une seule réponse. Nous comparerons votre choix collectif au classement par rapport effort / gain.

Vague 1 — Arrêter l'hémorragie

Jours 1 à 30 • huit mesures, aucune n'exige de budget d'investissement

1 Authentification multifacteur sur tous les accès distants et d'administration

2 Recensement des comptes à privilèges, suppression des comptes orphelins

3 Correctifs critiques sur tout ce qui est exposé sur Internet

4 Copie de sauvegarde hors ligne ou non modifiable des données critiques

5 Test de restauration réel sur un actif critique

6 Fermeture des accès d'administration exposés directement sur Internet

7 Journalisation des authentifications et des actions d'administration

8 Procédure de signalement d'incident sur une page, contacts d'urgence diffusés

Les cinq premières mesures répondent directement aux trois incidents de la première partie.

Pourquoi celles-là et pas d'autres

Le critère : combien d'attaques réelles cette mesure rend-elle impossibles ?

Ce que change l'authentification multifacteur

Elle neutralise la quasi-totalité des attaques fondées sur un mot de passe volé ou deviné — de loin le premier mode d'entrée observé dans les petites organisations.

Ce que change une sauvegarde hors ligne

Elle transforme un rançongiciel en incident d'exploitation de deux jours au lieu d'une négociation avec un attaquant.

Ce que change la journalisation

Sans journaux, on ne peut ni comprendre ce qui s'est passé, ni prouver ce qui n'a pas été volé. C'est souvent la question de l'assureur et du régulateur.

Aucune de ces trois mesures ne nécessite d'acheter un produit supplémentaire.

Vos sauvegardes : à quand remonte le dernier test de restauration réussi ?

A Moins de trois mois, avec un compte rendu écrit

B Entre trois mois et un an

C Plus d'un an, ou jamais testé

D Je ne sais pas qui serait en mesure de répondre

La réponse D est la plus fréquente — et c'est une réponse en soi.

La sauvegarde : la mesure la plus mal comprise

Ce qui compte n'est pas la copie, c'est la restauration démontrée

3

copies des données

2

supports différents

1

copie hors site

1

copie hors ligne ou non
modifiable

0

erreur au dernier test

Le piège le plus courant

Une sauvegarde accessible depuis le réseau, avec un compte disposant de droits d'écriture, est chiffrée en même temps que le reste. C'est ce qui s'est produit dans l'incident 1.

Le test qui compte

Restaurer un fichier ne prouve rien. Restaurer un service complet, chronométré, avec un compte rendu écrit : voilà la preuve.

Vague 2 — Structurer

Jours 31 à 60 • sept mesures qui demandent de la coordination, pas du budget

9

Séparation des comptes d'administration et des comptes de travail quotidiens

10

Gestionnaire de mots de passe et politique de phrases de passe

11

Durcissement des postes : chiffrement, pare-feu, antivirus centralisé, mises à jour

12

Encadrement des accès des prestataires : nominatifs, à durée limitée

13

Protection de la messagerie : SPF, DKIM, DMARC, bannière sur les courriels externes

14

Revue des partages de fichiers et suppression des liens publics inutiles

15

Session de sensibilisation et simulation d'hameçonnage

Mesure 13 : la protection du domaine de messagerie évite l'incident 2.

Vague 3 — Tenir dans la durée

Jours 61 à 90 • six mesures qui transforment l'effort en routine

- 16 Classification des données en quatre niveaux sur les principaux dépôts
- 17 Plan de réponse à incident d'une page, testé par un exercice sur table
- 18 Revue trimestrielle des accès : employés, prestataires, comptes de service
- 19 Alertes sur les connexions d'administration inhabituelles
- 20 Registre des dérogations et acceptation formelle des risques résiduels
- 21 Présentation du tableau de bord des cinq indicateurs à la direction

La mesure 21 est la plus importante des vingt et une : sans passage devant la direction, il n'y a pas de suite au-delà du 90e jour.

Ce qu'on ne fait pas les 90 premiers jours

Quatre projets légitimes, mais prématurés

Un test d'intrusion

Payer pour découvrir des faiblesses que vous savez déjà avoir. À faire une fois les vagues 1 et 2 terminées.

Un projet de certification

Douze à dix-huit mois d'effort documentaire. Utile, mais pas avant d'avoir des mesures à documenter.

Un outil de détection avancé

Sans journalisation ni inventaire, il produit du bruit que personne ne traitera.

Une refonte du réseau

Coûteuse, longue, et sans effet sur les trois incidents présentés en ouverture.

Aucun de ces quatre projets n'est inutile. Ils arrivent simplement après.

QUATRIÈME PARTIE

Prouver le progrès

Un plan qui ne se mesure pas est une intention. Cinq chiffres suffisent.

Les cinq indicateurs

Mesurables sans outil payant, compréhensibles par une direction

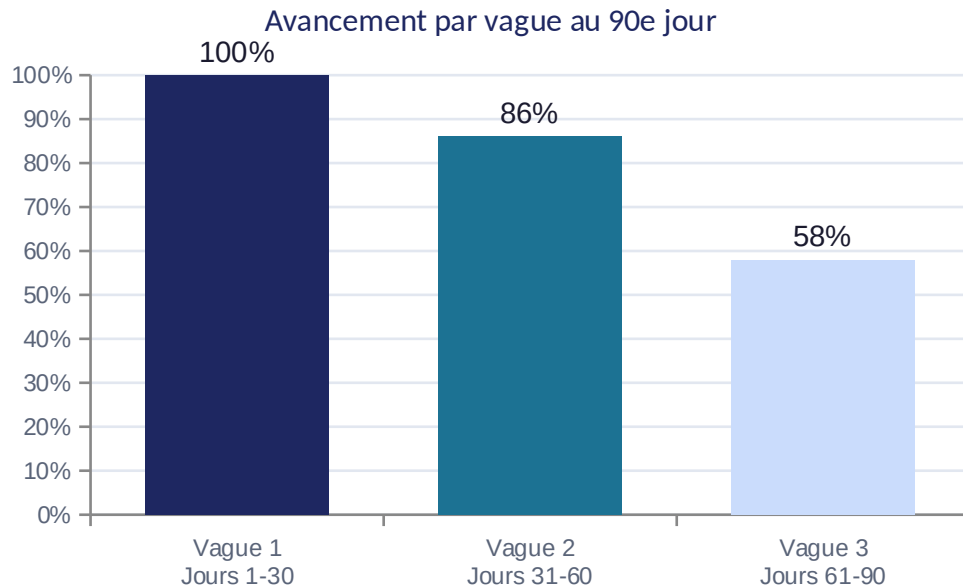
Indicateur	Valeur de départ typique	Cible à 90 jours
Comptes à privilèges protégés par MFA	30 %	100 %
Délai de correction des vulnérabilités exposées	45 jours	14 jours
Jours depuis le dernier test de restauration	Jamais testé	Moins de 90
Comptes inactifs depuis plus de 90 jours	18 %	Moins de 2 %
Part du plan 90 jours réalisée	0 %	100 %

Les valeurs de départ sont des ordres de grandeur observés dans de petites organisations n'ayant pas encore structuré leur sécurité.

Démonstration — le tableau de bord

DÉMONSTRATION

Ce que la direction de Groupe Diallo voit au 90e jour, en une seule page



83 %

du plan réalisé au 90e jour

4

mesures reportées, assumées et signées

0

franchissement de la vague suivante avant la fin de la précédente

Présenter tout cela à une direction

Trois reformulations qui font la différence

Ne dites pas

« Il nous faut un pare-feu de nouvelle génération à 15 000 000 FCFA. »

Dites

« Trois de nos actifs critiques n'ont pas de sauvegarde restaurable. Voici le coût d'un arrêt de onze jours. »

Parlez en jours d'arrêt

Un dirigeant ne convertit pas une vulnérabilité en risque. Il convertit un arrêt en perte de revenus.

Demandez une décision, pas un budget

« Acceptez-vous ce risque résiduel, ou financez-vous la mesure ? » — les deux réponses vous conviennent, car les deux sont tracées.

Revenez avec les mêmes cinq chiffres

La crédibilité vient de la répétition du même tableau, pas de la nouveauté du propos.

Qu'allez-vous mettre en œuvre dans les 30 prochains jours ?

- A L'inventaire des actifs avec la grille présentée
- B L'authentification multifacteur sur les comptes d'administration
- C Un test de restauration réel
- D Le retrait des comptes de prestataires et des comptes orphelins

Plusieurs réponses possibles. Ces résultats détermineront les approfondissements du prochain webinaire.

Votre classeur, prêt à remplir

Quatre onglets, environ deux heures de travail — lien affiché à l'écran et envoyé après la séance

1 Inventaire des actifs

Douze colonnes, échelle d'impact intégrée, criticité calculée automatiquement.

2 Plan 90 jours

Les 21 mesures, avec preuve attendue, effort, gain, responsable et échéance.

3 Indicateurs

Les cinq mesures de progrès, avec valeur de départ et cible à 90 jours.

4 Tableau de bord

Se calcule seul. C'est la page à projeter en comité de direction.

Lundi matin, 20 minutes : ouvrez l'onglet 1 et écrivez les cinq premiers actifs. C'est le seul engagement que je vous demande.

La question que je vous laisse

Réponse au prochain webinaire de la série

Vous avez appliqué les 21 mesures. Un compte d'administration légitime, avec le bon mot de passe et le bon second facteur, se connecte à 3 h du matin depuis un pays où vous n'avez aucune activité.

Qu'est-ce qui, dans votre dispositif, l'arrête ?

Prochain webinaire — Thème 2

L'identité, nouveau périmètre : mettre en œuvre le Zero Trust avec Microsoft Entra ID. De l'accès conditionnel au MFA résistant à l'hameçonnage.

D'ici là

Les cinq premières lignes de votre inventaire. Envoyez-les-moi : j'en commente deux en ouverture de la prochaine séance.

Questions

Posez-les dans le clavardage — je réponds à tout, y compris après la séance.

Isaïe Djrolo

Architecte sécurité

isaiedjrolo@gmail.com

Merci de votre participation.



Livable participants